

Network Segmentation & Firewall Policy Review - ABC Freight Forwarders (Lab)

Week 3 - Professional Advanced Build | Member 3 (Individual Contributor) | Primary Tool: **Windows Event Viewer**

1. Executive Summary

I designed and tested a network segmentation plan and firewall policy for a fictional independent freight forwarder, ABC Freight Forwarders. The network was split into five zones (IT, Office, Finance, Warehouse, Guest Wi-Fi), and Windows Defender Firewall rules were written so that only Finance and IT can reach the company Billing Portal. Every allowed and blocked connection was verified in Windows Event Viewer. All 5 zone tests passed. I then simulated an insider tampering attack that silently opened the portal to the Guest zone, detected both malicious changes in Event Viewer within seconds of each other, and reversed them.

2. Scope Statement

Client (fictional): ABC Freight Forwarders - an independent freight forwarder (~25 staff) that handles shipping documents, customs data, and client billing.

Business problem: All devices (staff PCs, finance, warehouse scanners, driver guest Wi-Fi) share one flat network. A single compromised device, such as a driver's phone on guest Wi-Fi, could reach the billing system. Freight forwarders are common targets for invoice fraud and ransomware, so the billing system needs to be isolated.

In scope

- Designing network zones (segmentation) based on business roles
- Writing a zone-to-service firewall policy matrix
- Implementing the policy with Windows Defender Firewall
- Verifying allowed and blocked traffic with Windows Event Viewer
- Detecting unauthorized firewall rule changes (tampering)

Out of scope

- Physical switches, VLAN hardware, or a dedicated perimeter firewall
- Outbound (egress) filtering
- Cloud services and email security

Lab limitation (honest note): Zones are simulated with IP ranges inside one host-only network (192.168.56.0/24). In a real office, zones would be separate VLANs with a router/firewall between them. The host laptop acts as the company server.

How this differs from Weeks 1 and 2: Week 1 hardened a single endpoint (real estate agency) and Week 2 detected failed logins on one machine (retail, Event ID 4625). Week 3 moves from the single machine to the **network**: controlling which groups of devices can talk to which service, proving it with Filtering Platform events (5152/5156), and monitoring the firewall itself for tampering (4946/4947/4948).

3. Lab Environment

Component	Details	Role
Host laptop	Windows 10 (build 19045), 192.168.56.1	Company server (Billing Portal)
Kali Linux 2026.2	VirtualBox VM, Host-only adapter (eth1)	Test client acting as all 5 zones
Billing Portal	PowerShell HttpListener, TCP 8080	Business service being protected
Windows Defender Firewall	Inbound rules scoped by remote IP	Policy enforcement
Windows Event Viewer	Security log, custom XPath filters	Verification and detection
Tools on Kali	<code>nmap</code> , <code>curl --interface</code> , <code>ip addr</code>	Scanning and zone testing

Kali's Host-only IP and the host's adapter:

```

kali@kali: ~
Session Actions Edit View Help

link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
inet 127.0.0.1/8 scope host lo
    valid_lft forever preferred_lft forever
inet6 ::1/128 scope host noprefixroute
    valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP g
rouper default qlen 1000
    link/ether 08:00:27:5a:87:bc brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
        valid_lft 85433sec preferred_lft 85433sec
    inet6 fd17:625c:f037:2:60d6:7aac:9d9c:8098/64 scope global dynamic nopref
ixroute
        valid_lft 85849sec preferred_lft 13849sec
    inet6 fe80::60a8:a7dd:30df:1246/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP g
rouper default qlen 1000
    link/ether 08:00:27:c5:f7:ab brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.101/24 brd 192.168.56.255 scope global dynamic noprefixro
ute eth1
        valid_lft 533sec preferred_lft 533sec
    inet6 fe80::a55:ee15:3285:2c3d/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

(kali@kali)-[~]
$ ping 192.168.56.1
PING 192.168.56.1 (192.168.56.1) 56(84) bytes of data.

```

Kali host-only IP

```

C:\ Command Prompt

Media State . . . . . : Media disconnected
Connection-specific DNS Suffix . :

Ethernet adapter VirtualBox Host-Only Network:

Connection-specific DNS Suffix . :
Link-local IPv6 Address . . . . . : fe80::8b44:90ad:5f96:bf0b%12
IPv4 Address. . . . . : 192.168.56.1
Subnet Mask . . . . . : 255.255.255.0
Default Gateway . . . . . :

Wireless LAN adapter Local Area Connection* 9:

Media State . . . . . : Media disconnected
Connection-specific DNS Suffix . :

Wireless LAN adapter Local Area Connection* 10:

Media State . . . . . : Media disconnected
Connection-specific DNS Suffix . :

Wireless LAN adapter Wi-Fi:

Connection-specific DNS Suffix . :
Link-local IPv6 Address . . . . . : fe80::353c:e4bf:d7fd:24ed%17
IPv4 Address. . . . . : 192.168.1.66
Subnet Mask . . . . . : 255.255.255.0
Default Gateway . . . . . : 192.168.1.1

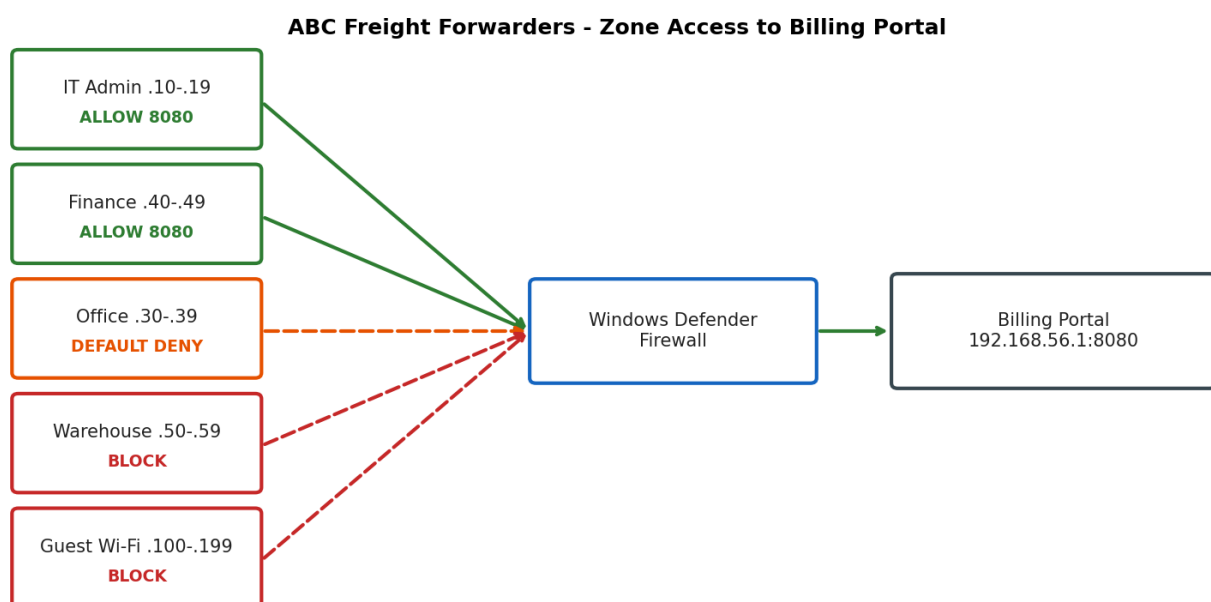
C:\Users\ls>

```

Host ipconfig

4. Segmentation Design

Zone	IP Range	Who	Needs Billing Portal?
IT / Admin	192.168.56.10 - .19	IT staff	Yes (maintenance)
Office Staff	192.168.56.30 - .39	Operations, sales	No
Finance	192.168.56.40 - .49	Accounts team	Yes (invoicing)
Warehouse	192.168.56.50 - .59	Scanners, CCTV	No
Guest Wi-Fi	192.168.56.100 - .199	Drivers, visitors	Never



Segmentation diagram

5. Firewall Policy Matrix

#	Rule Name	Source	Port	Action	Business Reason
1	FF-ALLOW Billing Portal from Finance	.40 - .49	TCP 8080	Allow	Finance creates invoices
2	FF-ALLOW Billing Portal from IT	.10 - .19	TCP 8080	Allow	IT maintains the system
3	FF-BLOCK Guest Zone	.100 - .199	All	Block	Drivers need internet only
4	FF-BLOCK Warehouse Zone	.50 - .59	All	Block	Scanners/CCTV never need the server
-	(no rule)	Office .30 - .39	All	Default Deny	Least privilege: not needed for their job

All custom rules use the **FF-** prefix so they are easy to audit. Script: `scripts/firewall-policy.ps1`

```

Administrator: Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Try the new cross-platform PowerShell https://aka.ms/pscore6

PS C:\Windows\system32> New-NetFirewallRule -DisplayName "FF-ALLOW Billing Portal from Finance" -Direction Inbound -Protocol TCP -LocalPort 8080 -RemoteAddress 192.168.56.40-192.168.56.49 -Action Allow

Name                           : {c5cdbe40-e4a8-445e-b000-18f518aed0e7}
DisplayName                     : FF-ALLOW Billing Portal from Finance
Description                     :
DisplayGroup                    :
Group                           :
Enabled                         : True
Profile                         : Any
Platform                       : {}
Direction                      : Inbound
Action                          : Allow
EdgeTraversalPolicy             : Block
LooseSourceMapping              : False
LocalOnlyMapping               : False
Owner                           :
PrimaryStatus                   : OK
Status                          : The rule was parsed successfully from the store. (65536)
EnforcementStatus               : NotApplicable
PolicyStoreSource               : PersistentStore
PolicyStoreSourceType           : Local
RemoteDynamicKeywordAddresses  :
PolicyAppId                     :

PS C:\Windows\system32> New-NetFirewallRule -DisplayName "FF-ALLOW Billing Portal from IT" -Direction Inbound -Protocol TCP -LocalPort 8080 -RemoteAddress 192.168.56.10-192.168.56.19 -Action Allow

Name                           : {280bf6c4-67a9-4744-9c11-9f7d60189d51}
DisplayName                     : FF-ALLOW Billing Portal from IT
Description                     :
DisplayGroup                    :
Group                           :
Enabled                         : True
Profile                         : Any
Platform                       : {}
Direction                      : Inbound
Action                          : Allow
EdgeTraversalPolicy             : Block
LooseSourceMapping              : False
LocalOnlyMapping               : False
Owner                           :
PrimaryStatus                   : OK
Status                          : The rule was parsed successfully from the store. (65536)

```

Rules created 1

```
Administrator: Windows PowerShell
PrimaryStatus      : OK
Status             : The rule was parsed successfully from the store. (65536)
EnforcementStatus  : NotApplicable
PolicyStoreSource  : PersistentStore
PolicyStoreSourceType : Local
RemoteDynamicKeywordAddresses :
PolicyAppId        :

PS C:\Windows\system32> New-NetFirewallRule -DisplayName "FF-BLOCK Guest Zone" -Direction Inbound -RemoteAddress 192.168.56.100-192.168.56.199 -Action Block

Name                : {4673825a-398f-4878-9b62-8dd79adc3d1}
DisplayName          : FF-BLOCK Guest Zone
Description          :
DisplayGroup         :
Group               :
Enabled              : True
Profile              : Any
Platform             : {}
Direction            : Inbound
Action               : Block
EdgeTraversalPolicy  : Block
LooseSourceMapping   : False
LocalOnlyMapping     : False
Owner                :
PrimaryStatus        : OK
Status               : The rule was parsed successfully from the store. (65536)
EnforcementStatus    : NotApplicable
PolicyStoreSource    : PersistentStore
PolicyStoreSourceType : Local
RemoteDynamicKeywordAddresses :
PolicyAppId          :

PS C:\Windows\system32> New-NetFirewallRule -DisplayName "FF-BLOCK Warehouse Zone" -Direction Inbound -RemoteAddress 192.168.56.50-192.168.56.59 -Action Block

Name                : {f8118423-e12e-41ec-9fb1-1ee4d1690bb1}
DisplayName          : FF-BLOCK Warehouse Zone
Description          :
DisplayGroup         :
Group               :
Enabled              : True
Profile              : Any
Platform             : {}
Direction            : Inbound
Action               : Block
EdgeTraversalPolicy  : Block
LooseSourceMapping   : False
LocalOnlyMapping     : False
Owner                :
PrimaryStatus        : OK
Status               : The rule was parsed successfully from the store. (65536)
EnforcementStatus    : NotApplicable
PolicyStoreSource    : PersistentStore
PolicyStoreSourceType : Local
RemoteDynamicKeywordAddresses :
PolicyAppId          :
```

Rules created 2

```
Administrator: Windows PowerShell
Name                : {4673825a-398f-4878-9b62-8dd79adc3d1}
DisplayName          : FF-BLOCK Guest Zone
Description          :
DisplayGroup         :
Group               :
Enabled              : True
Profile              : Any
Platform             : {}
Direction            : Inbound
Action               : Block
EdgeTraversalPolicy  : Block
LooseSourceMapping   : False
LocalOnlyMapping     : False
Owner                :
PrimaryStatus        : OK
Status               : The rule was parsed successfully from the store. (65536)
EnforcementStatus    : NotApplicable
PolicyStoreSource    : PersistentStore
PolicyStoreSourceType : Local
RemoteDynamicKeywordAddresses :
PolicyAppId          :

PS C:\Windows\system32> New-NetFirewallRule -DisplayName "FF-BLOCK Warehouse Zone" -Direction Inbound -RemoteAddress 192.168.56.50-192.168.56.59 -Action Block

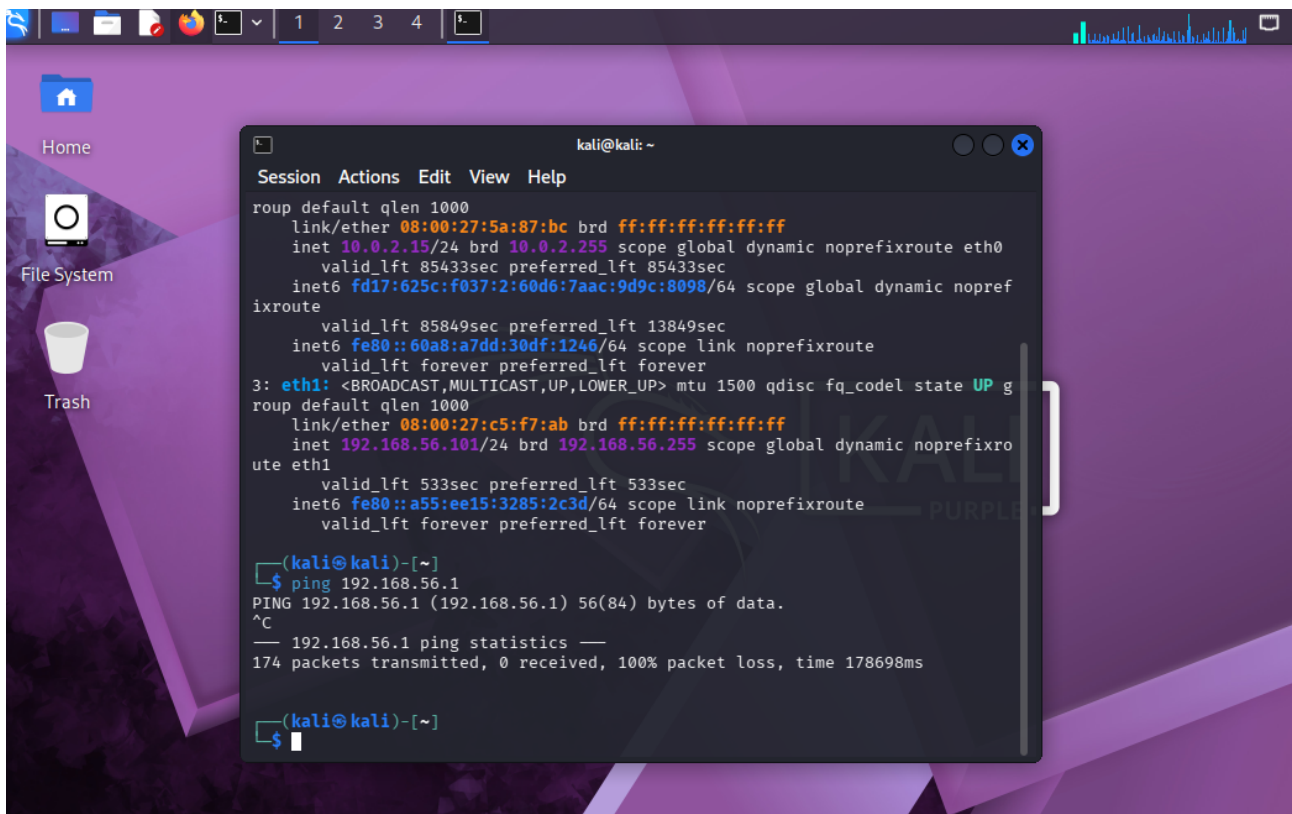
Name                : {f8118423-e12e-41ec-9fb1-1ee4d1690bb1}
DisplayName          : FF-BLOCK Warehouse Zone
Description          :
DisplayGroup         :
Group               :
Enabled              : True
Profile              : Any
Platform             : {}
Direction            : Inbound
Action               : Block
EdgeTraversalPolicy  : Block
LooseSourceMapping   : False
LocalOnlyMapping     : False
Owner                :
PrimaryStatus        : OK
Status               : The rule was parsed successfully from the store. (65536)
EnforcementStatus    : NotApplicable
PolicyStoreSource    : PersistentStore
PolicyStoreSourceType : Local
RemoteDynamicKeywordAddresses :
PolicyAppId          :

PS C:\Windows\system32>
```

Rules created 3

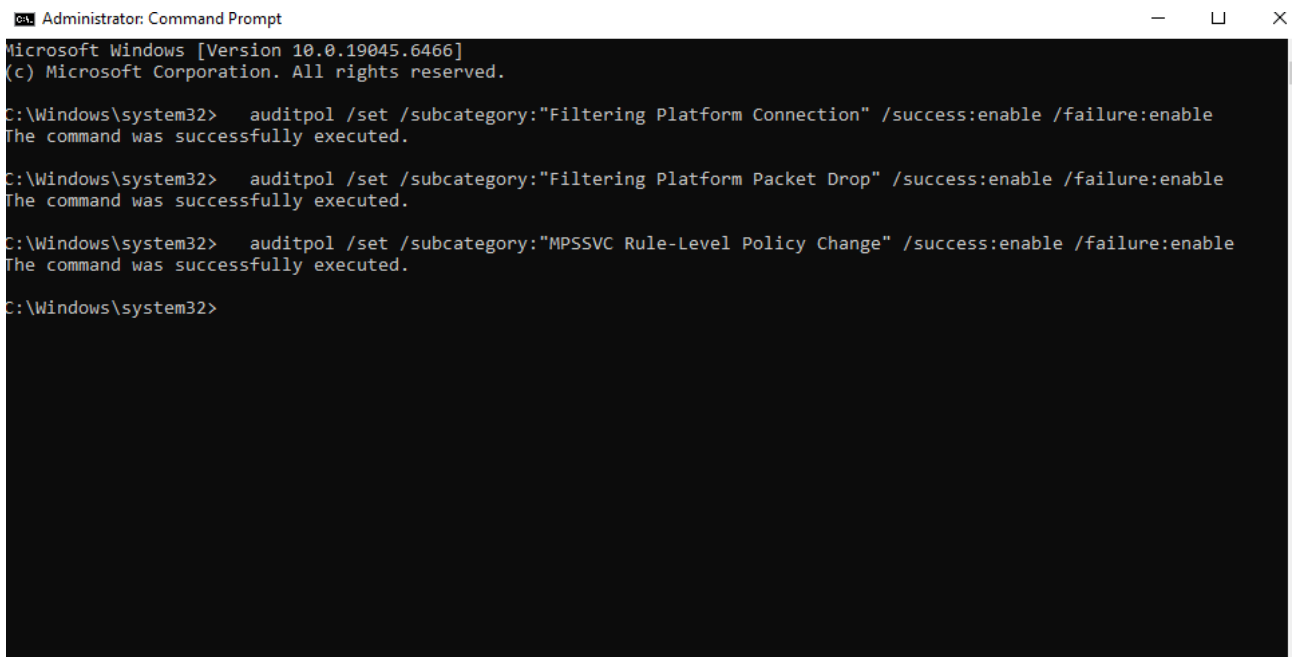
6. Implementation Steps

Step 1 - Baseline. Ping from Kali to the host failed (174 sent, 0 received).



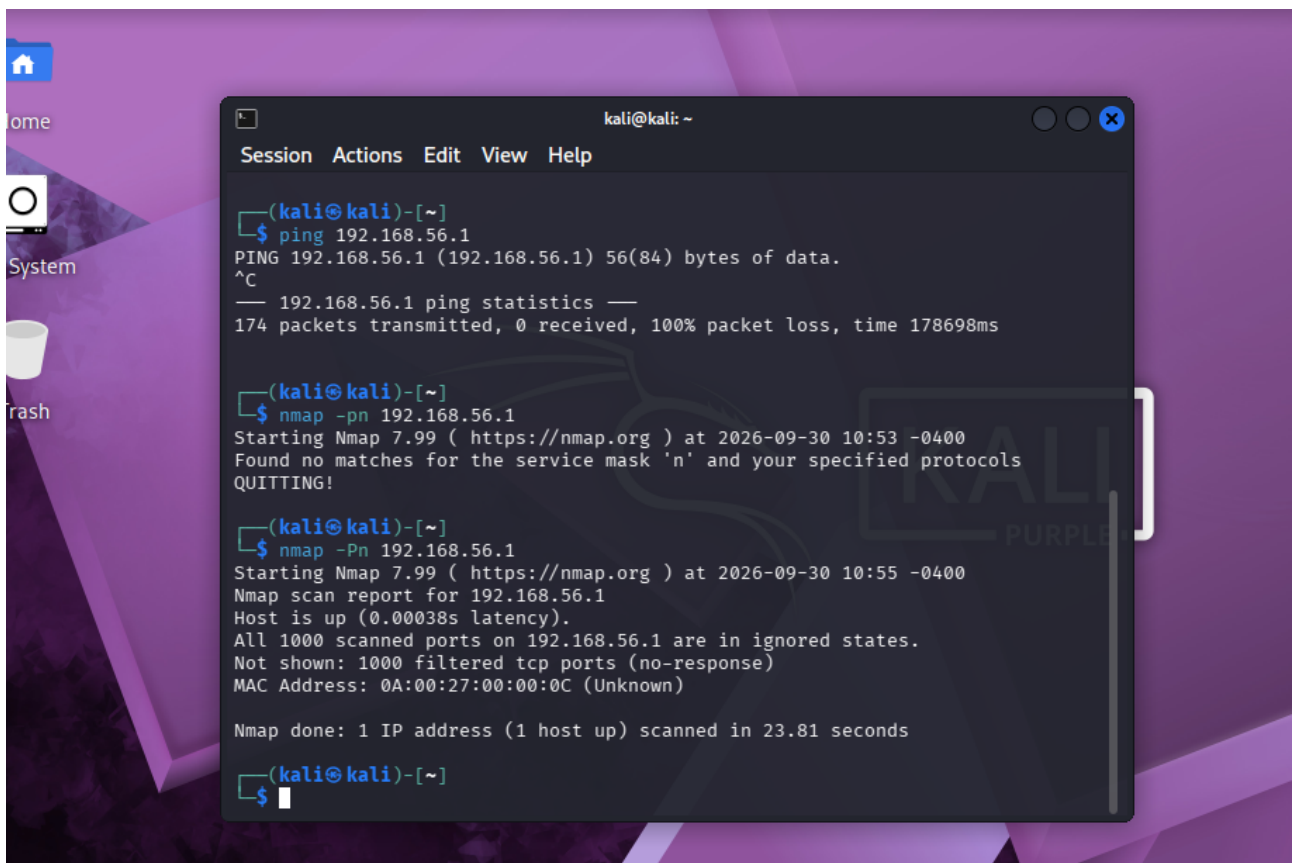
Ping blocked

Step 2 - Enable auditing. Windows does not log allowed/blocked connections or rule changes by default.



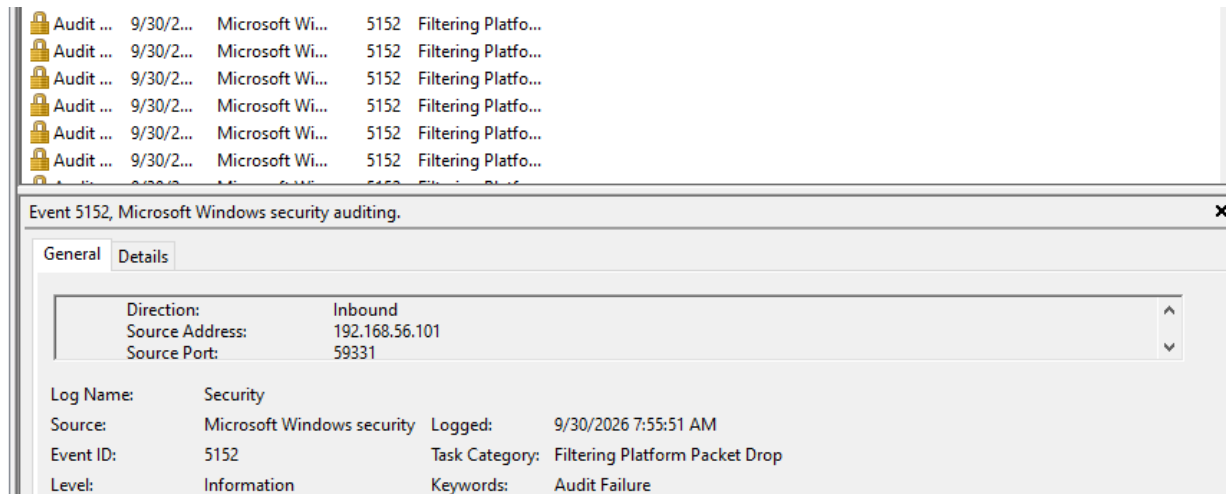
auditpol

Step 3 - Baseline scan from the Guest zone. All 1000 common TCP ports were filtered.



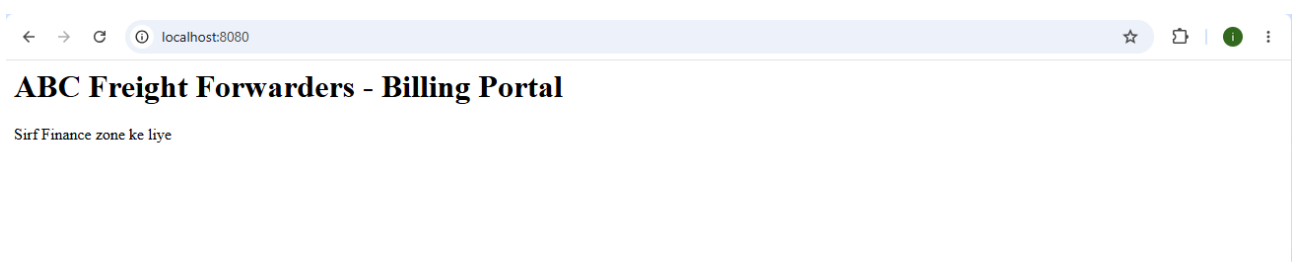
nmap before

The drops were visible in Event Viewer (Event 5152, Source 192.168.56.101):



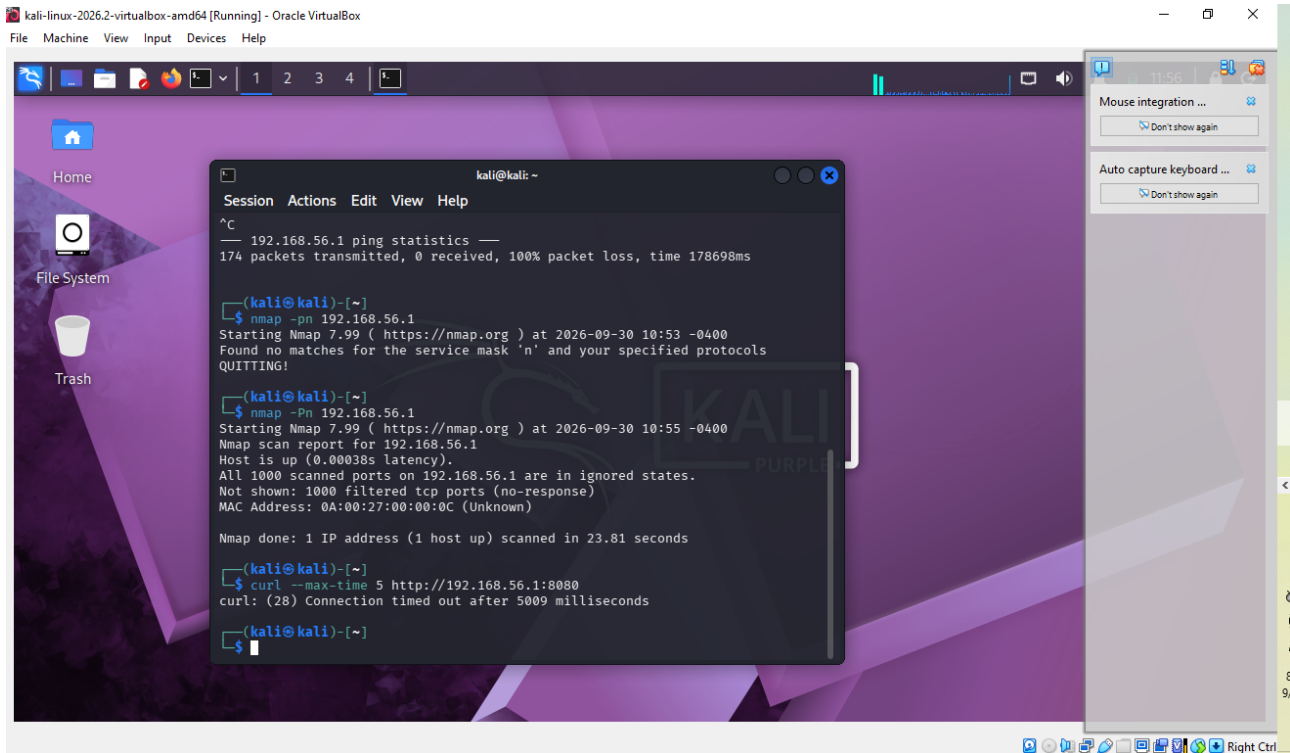
First 5152

Step 4 - Start the Billing Portal on TCP 8080 (`scripts/billing-portal.ps1`).



Portal running

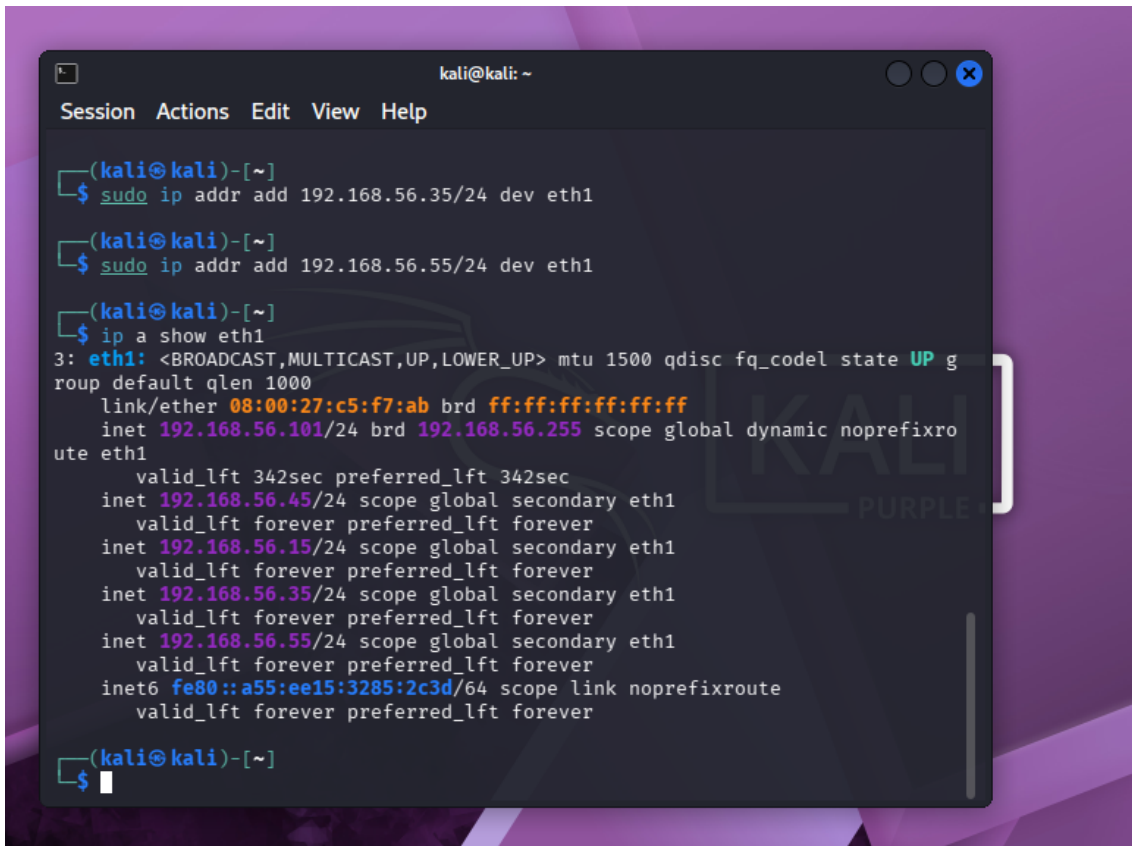
Before any rules, the Guest zone could not reach it:



Guest blocked before rules

Step 5 - Create the four FF- rules (Section 5).

Step 6 - Give Kali one IP per zone (scripts/kali-zone-tests.sh).



Kali zone IPs

Step 7 - Test every zone and verify in Event Viewer (Section 7).

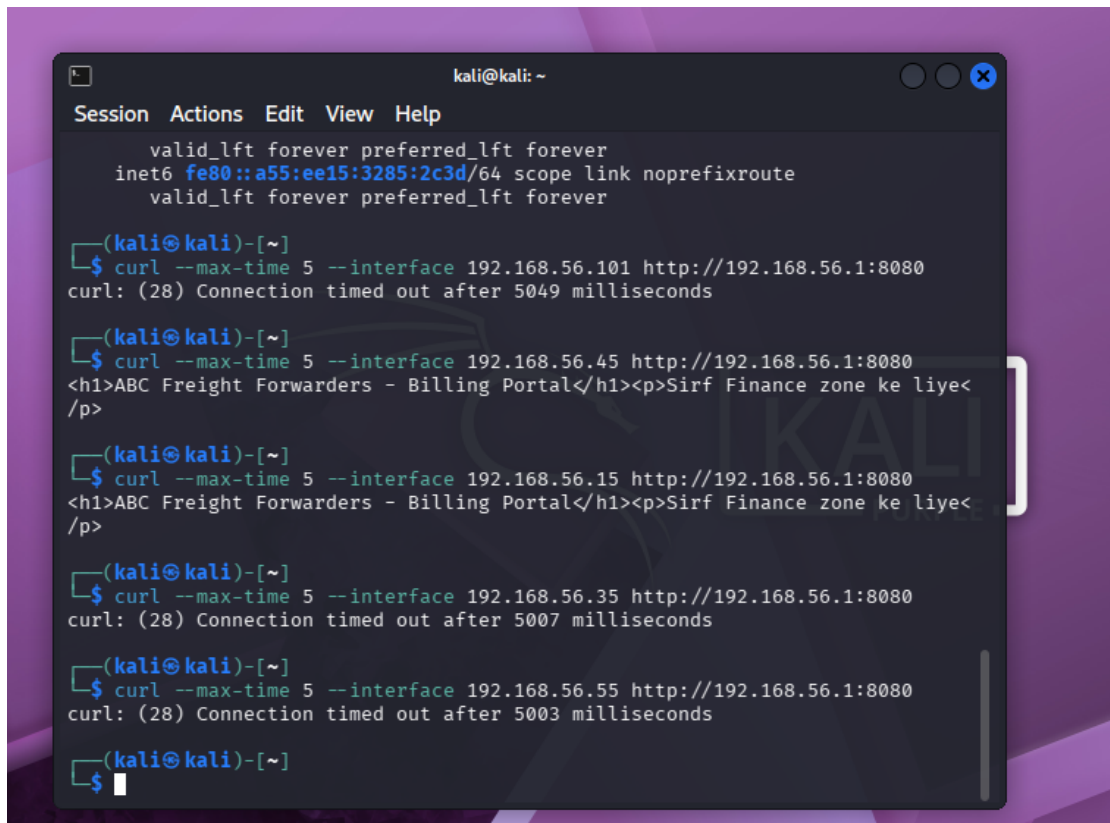
Step 8 - Simulate tampering, detect it, and fix it (Section 8, F5).

7. Testing & Evidence

Zone access tests (after rules)

Test	Zone	Source IP	Expected	Result	Evidence	Status
1	Guest	.101	Block	Timed out	Event 5152	PASS
2	Finance	.45	Allow	Page loaded	Event 5156 + portal log	PASS
3	IT Admin	.15	Allow	Page loaded	Portal log	PASS
4	Office	.35	Block (default deny)	Timed out	-	PASS
5	Warehouse	.55	Block	Timed out	-	PASS

Result: 5 / 5 passed.



```
kali@kali: ~
Session Actions Edit View Help

valid_lft forever preferred_lft forever
inet6 fe80::a55:ee15:3285:2c3d/64 scope link noprefixroute
valid_lft forever preferred_lft forever

(kali@kali)-[~]
$ curl --max-time 5 --interface 192.168.56.101 http://192.168.56.1:8080
curl: (28) Connection timed out after 5049 milliseconds

(kali@kali)-[~]
$ curl --max-time 5 --interface 192.168.56.45 http://192.168.56.1:8080
<h1>ABC Freight Forwarders - Billing Portal</h1><p>Sirf Finance zone ke liye</p>

(kali@kali)-[~]
$ curl --max-time 5 --interface 192.168.56.15 http://192.168.56.1:8080
<h1>ABC Freight Forwarders - Billing Portal</h1><p>Sirf Finance zone ke liye</p>

(kali@kali)-[~]
$ curl --max-time 5 --interface 192.168.56.35 http://192.168.56.1:8080
curl: (28) Connection timed out after 5007 milliseconds

(kali@kali)-[~]
$ curl --max-time 5 --interface 192.168.56.55 http://192.168.56.1:8080
curl: (28) Connection timed out after 5003 milliseconds

(kali@kali)-[~]
$
```

5 of 5 tests

Server-side proof: the Billing Portal's own log shows requests only from **.45** (Finance) and **.15** (IT). Blocked zones never reached the service.

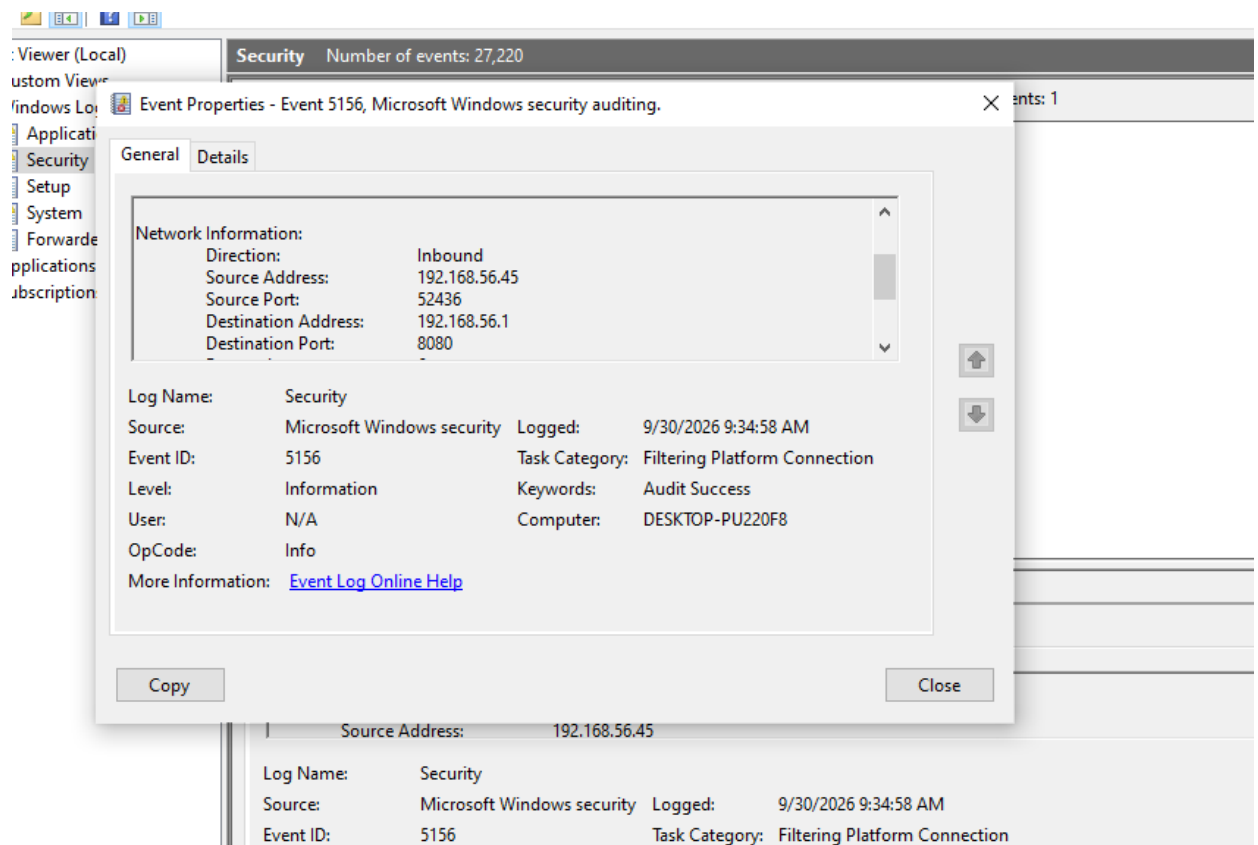
```
Administrator: Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Try the new cross-platform PowerShell https://aka.ms/pscore6

PS C:\Windows\system32> $l = New-Object System.Net.HttpListener
>> $l.Prefixes.Add("http://+:8080/")
>> $l.Start()
>> Write-Host "ABC Freight Billing Portal chal raha hai (port 8080)..." -ForegroundColor Green
>> while ($l.IsListening) {
>>     $c = $l.GetContext()
>>     $ip = $c.Request.RemoteEndPoint.Address
>>     Write-Host "Request aayi: $ip" -ForegroundColor Yellow
>>     $html = "<h1>ABC Freight Forwarders - Billing Portal</h1><p>Sirf Finance zone ke liye</p>"
>>     $b = [Text.Encoding]::UTF8.GetBytes($html)
>>     $c.Response.OutputStream.Write($b, 0, $b.Length)
>>     $c.Response.Close()
>> }
ABC Freight Billing Portal chal raha hai (port 8080)...
Request aayi: 192.168.56.45
Request aayi: 192.168.56.15
```

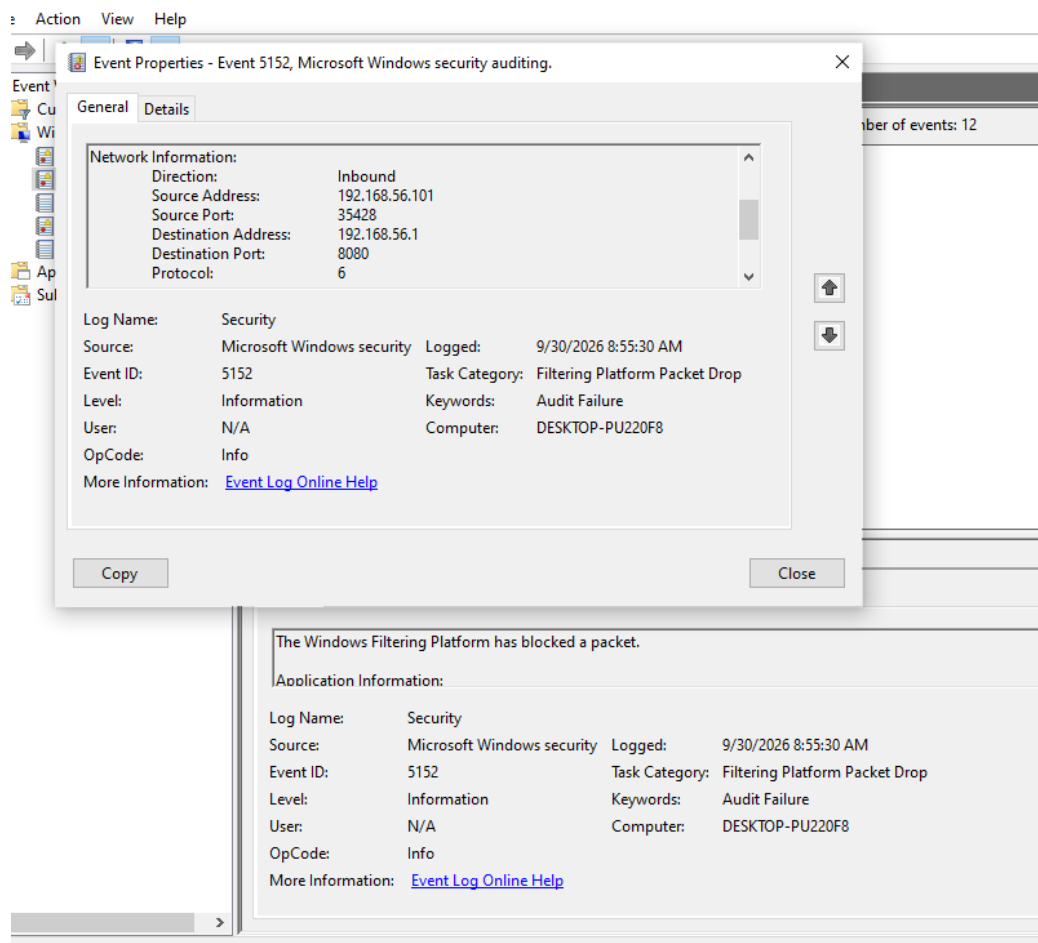
Portal log

Allowed - Event 5156: Finance (192.168.56.45) -> 192.168.56.1, port 8080, Audit Success.

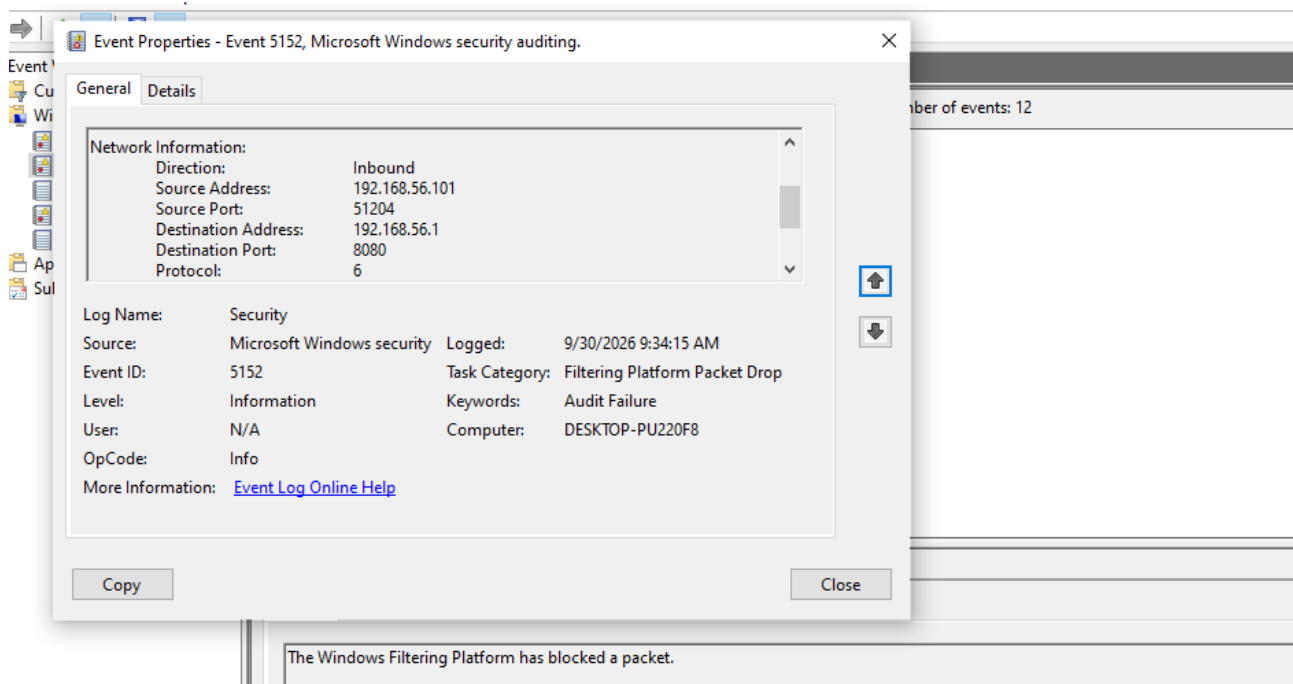


5156 Finance allowed

Blocked - Event 5152: Guest (192.168.56.101) -> port 8080, Audit Failure. One event from before the rules (08:55) and one after (09:34):



5152 before



5152 after

Event IDs used

Event ID	Meaning	Where
5152	Packet dropped (blocked)	Security log
5156	Connection allowed	Security log
4946	Firewall rule added	Security log
4947	Firewall rule modified	Security log
4948	Firewall rule deleted	Security log

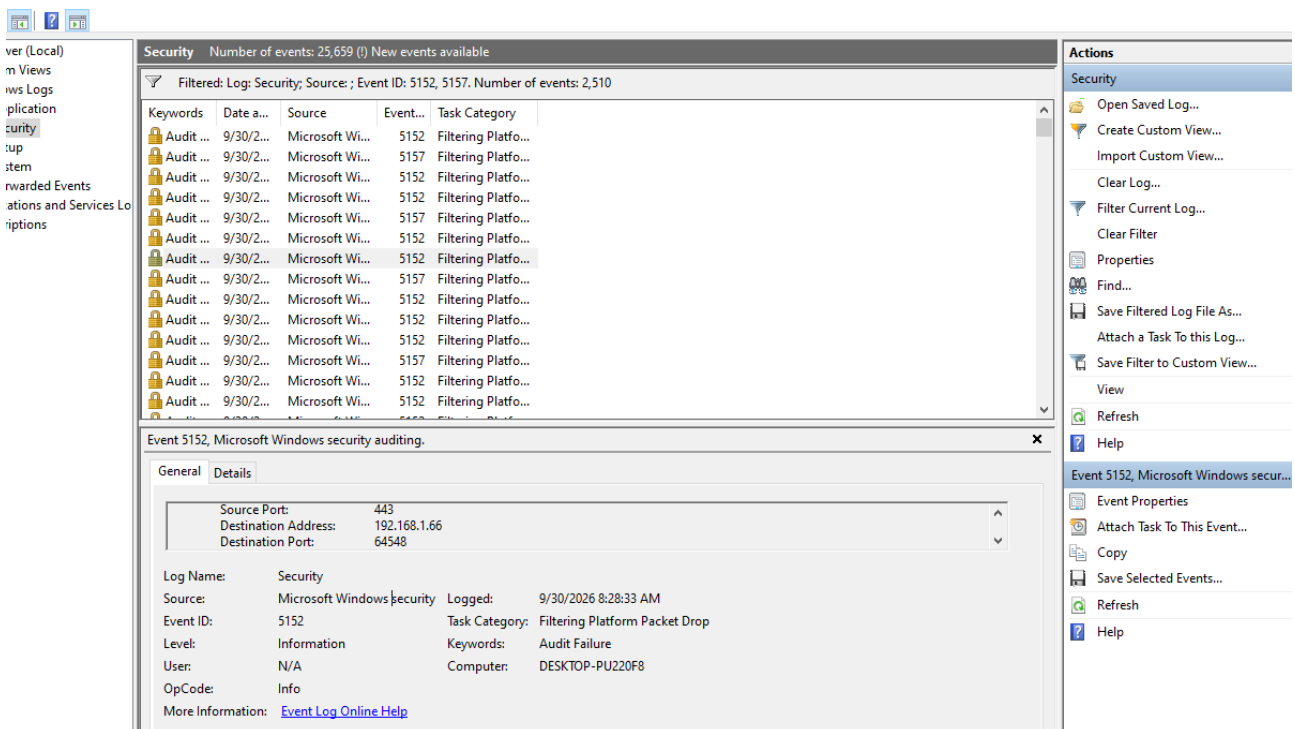
Filters used: `scripts/eventviewer-filters.xml`

8. Findings & Fixes

F1 - Security logging disabled by default. Windows does not log allowed/blocked connections or rule changes until audit subcategories are enabled. *Fix:* enabled via `auditpol`.

F2 - Everything blocked, including needed services. All 1000 ports were filtered from the Guest zone. Secure, but unusable for a business that needs Finance to reach billing. *Fix:* scoped allow rules per zone instead of opening ports to everyone.

F3 - Log noise. The Security log held 27,000+ events, mostly the host's own internet and Chrome traffic. A single Guest scan produced 2,010 drop events. Filtering by Event ID alone was not enough. *Fix:* XPath filters by Event ID + source IP + destination port.



The screenshot shows the Windows Event Viewer interface. The left pane shows the 'Security' log selected. The main pane displays a list of events filtered by 'Log: Security; Source: ; Event ID: 5152, 5157'. The list shows multiple 'Audit ...' events from 'Microsoft Windows security auditing' with Event IDs 5152 and 5157. The details pane for Event 5152 shows 'Filtering Platform Packet Drop'.

Keywords	Date a...	Source	Event...	Task Category
Audit ...	9/30/2...	Microsoft Wi...	5152	Filtering Platfo...
Audit ...	9/30/2...	Microsoft Wi...	5157	Filtering Platfo...
Audit ...	9/30/2...	Microsoft Wi...	5152	Filtering Platfo...
Audit ...	9/30/2...	Microsoft Wi...	5152	Filtering Platfo...
Audit ...	9/30/2...	Microsoft Wi...	5157	Filtering Platfo...
Audit ...	9/30/2...	Microsoft Wi...	5152	Filtering Platfo...
Audit ...	9/30/2...	Microsoft Wi...	5152	Filtering Platfo...
Audit ...	9/30/2...	Microsoft Wi...	5157	Filtering Platfo...
Audit ...	9/30/2...	Microsoft Wi...	5152	Filtering Platfo...
Audit ...	9/30/2...	Microsoft Wi...	5152	Filtering Platfo...
Audit ...	9/30/2...	Microsoft Wi...	5157	Filtering Platfo...
Audit ...	9/30/2...	Microsoft Wi...	5152	Filtering Platfo...
Audit ...	9/30/2...	Microsoft Wi...	5152	Filtering Platfo...

Event 5152, Microsoft Windows security auditing.

General	Details
Source Port: 443	
Destination Address: 192.168.1.66	
Destination Port: 64548	
Log Name: Security	
Source: Microsoft Windows security	Logged: 9/30/2026 8:28:33 AM
Event ID: 5152	Task Category: Filtering Platform Packet Drop
Level: Information	Keywords: Audit Failure
User: N/A	Computer: DESKTOP-PU220F8
OpCode: Info	
More Information: Event Log Online Help	

Noise: internet traffic

Views

Logs

Application

Security

System

Forwarded Events

Applications and Services Logs

Options

Keywords	Date a...	Source	Event...	Task Category
Audit ...	9/30/2...	Microsoft Wi...	5156	Filtering Platfo...
Audit ...	9/30/2...	Microsoft Wi...	5156	Filtering Platfo...
Audit ...	9/30/2...	Microsoft Wi...	5156	Filtering Platfo...
Audit ...	9/30/2...	Microsoft Wi...	5156	Filtering Platfo...
Audit ...	9/30/2...	Microsoft Wi...	5156	Filtering Platfo...
Audit ...	9/30/2...	Microsoft Wi...	5156	Filtering Platfo...
Audit ...	9/30/2...	Microsoft Wi...	5156	Filtering Platfo...
Audit ...	9/30/2...	Microsoft Wi...	5156	Filtering Platfo...
Audit ...	9/30/2...	Microsoft Wi...	5156	Filtering Platfo...
Audit ...	9/30/2...	Microsoft Wi...	5156	Filtering Platfo...
Audit ...	9/30/2...	Microsoft Wi...	5156	Filtering Platfo...
Audit ...	9/30/2...	Microsoft Wi...	5156	Filtering Platfo...
Audit ...	9/30/2...	Microsoft Wi...	5156	Filtering Platfo...
Audit ...	9/30/2...	Microsoft Wi...	5156	Filtering Platfo...
Audit ...	9/30/2...	Microsoft Wi...	5156	Filtering Platfo...
Audit ...	9/30/2...	Microsoft Wi...	5156	Filtering Platfo...

Event 5156, Microsoft Windows security auditing.

General

Details

Application Information:

Process ID:

8664

Application Name:

\\device\\harddiskvolume3\\program files\\google\\chrome\\application\\chrome.exe

Log Name:

Security

Source:

Microsoft Windows security

Logged:

9/30/2026 10:07:48 AM

Event ID:

5156

Task Category:

Filtering Platform Connection

Level:

Information

Keywords:

Audit Success

User:

N/A

Computer:

DESKTOP-PU220F8

OpCode:

Info

More Information:

[Event Log Online Help](#)

Noise: Chrome

Views

Logs

Application

Security

System

Forwarded Events

Applications and Services Logs

Options

Filtered: Advanced filter, click on "Filter" command to view filter configuration.. Number of events: 2,010

Keywords	Date a...	Source	Event...	Task Category
Audit ...	9/30/2...	Microsoft Wi...	5152	Filtering Platfo...

Event Properties - Event 5152, Microsoft Windows security auditing.

General

Details

Application Name:

-

Network Information:

Direction:

Inbound

Source Address:

192.168.56.101

Source Port:

59329

Destination Address:

192.168.56.1

Log Name:

Security

Source:

Microsoft Windows security

Logged:

9/30/2026 7:55:36 AM

Event ID:

5152

Task Category:

Filtering Platform Packet Drop

Level:

Information

Keywords:

Audit Failure

User:

N/A

Computer:

DESKTOP-PU220F8

OpCode:

Info

More Information:

[Event Log Online Help](#)

Copy

Close

2010 drops from nmap

F4 - Bug in the Billing Portal script. The client IP printed empty because it was read after the connection was closed. *Fix:* read `RemoteEndPoint` before `Response.Close()`.

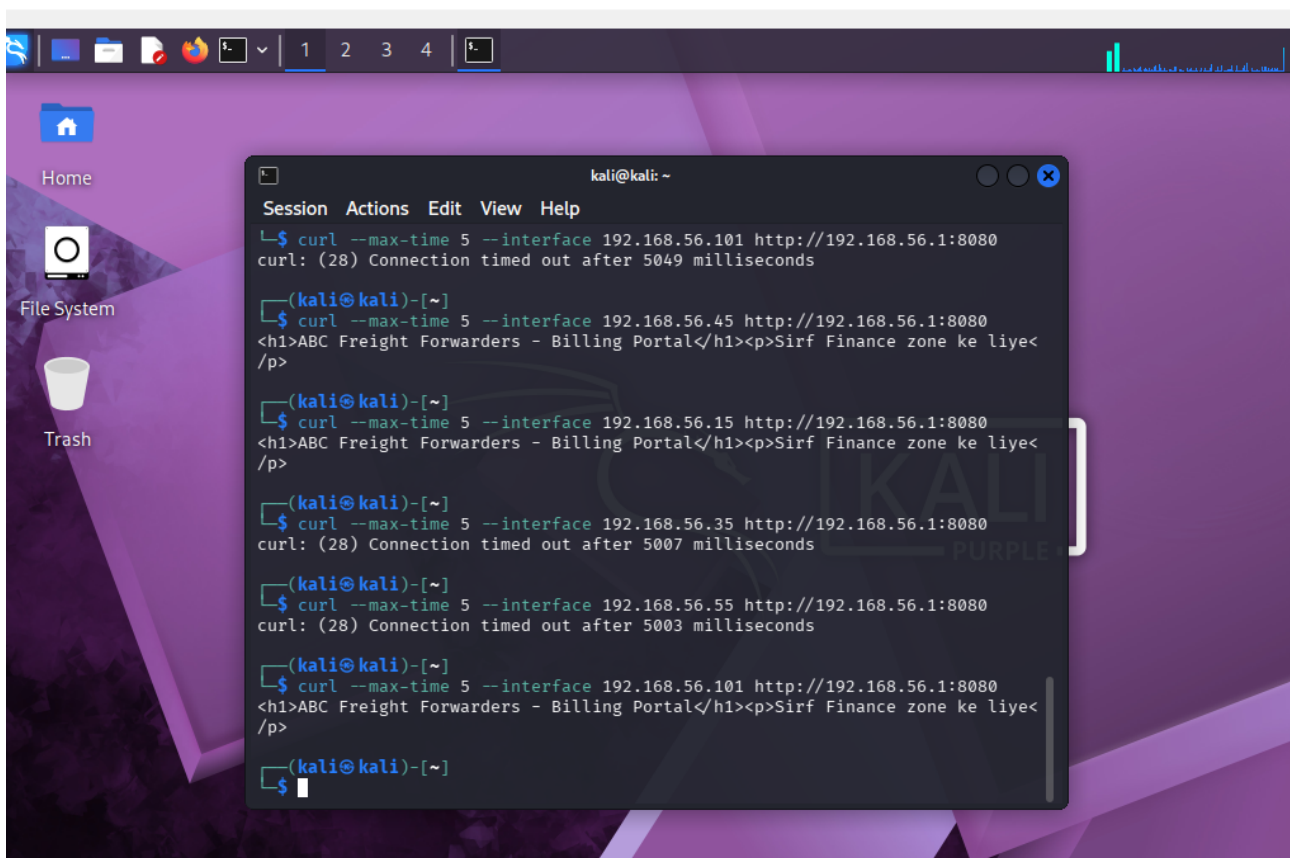
```
Administrator: Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Try the new cross-platform PowerShell https://aka.ms/pscore6

PS C:\Windows\system32> $1 = New-Object System.Net.HttpListener
>> $1.Prefixes.Add("http://+:8080/")
>> $1.Start()
>> Write-Host "ABC Freight Billing Portal chal raha hai (port 8080)..." -ForegroundColor Green
>> while ($1.IsListening) {
>>     $c = $1.GetContext()
>>     $html = "<h1>ABC Freight Forwarders - Billing Portal</h1><p>Sirf Finance zone ke liye</p>"
>>     $b = [Text.Encoding]::UTF8.GetBytes($html)
>>     $c.Response.OutputStream.Write($b, 0, $b.Length)
>>     $c.Response.Close()
>>     Write-Host "Request aayi: $($c.Request.RemoteEndPoint)" -ForegroundColor Yellow
>> }
ABC Freight Billing Portal chal raha hai (port 8080)...
Request aayi:
Request aayi:
```

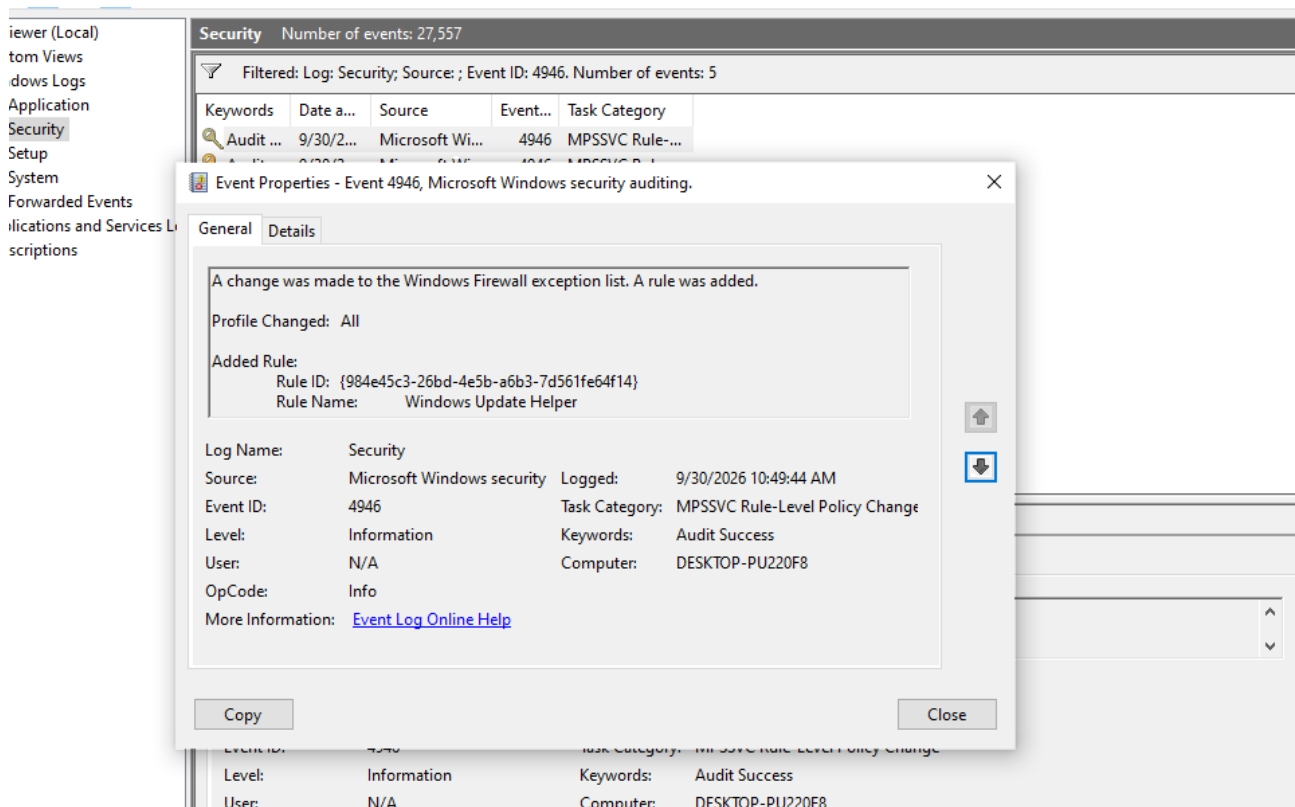
Bug: empty IP

F5 - Tampering breaks segmentation silently. Acting as an insider with admin rights, I disabled `FF-BLOCK Guest Zone` and added an allow rule disguised as "Windows Update Helper". The Guest zone then loaded the Billing Portal.

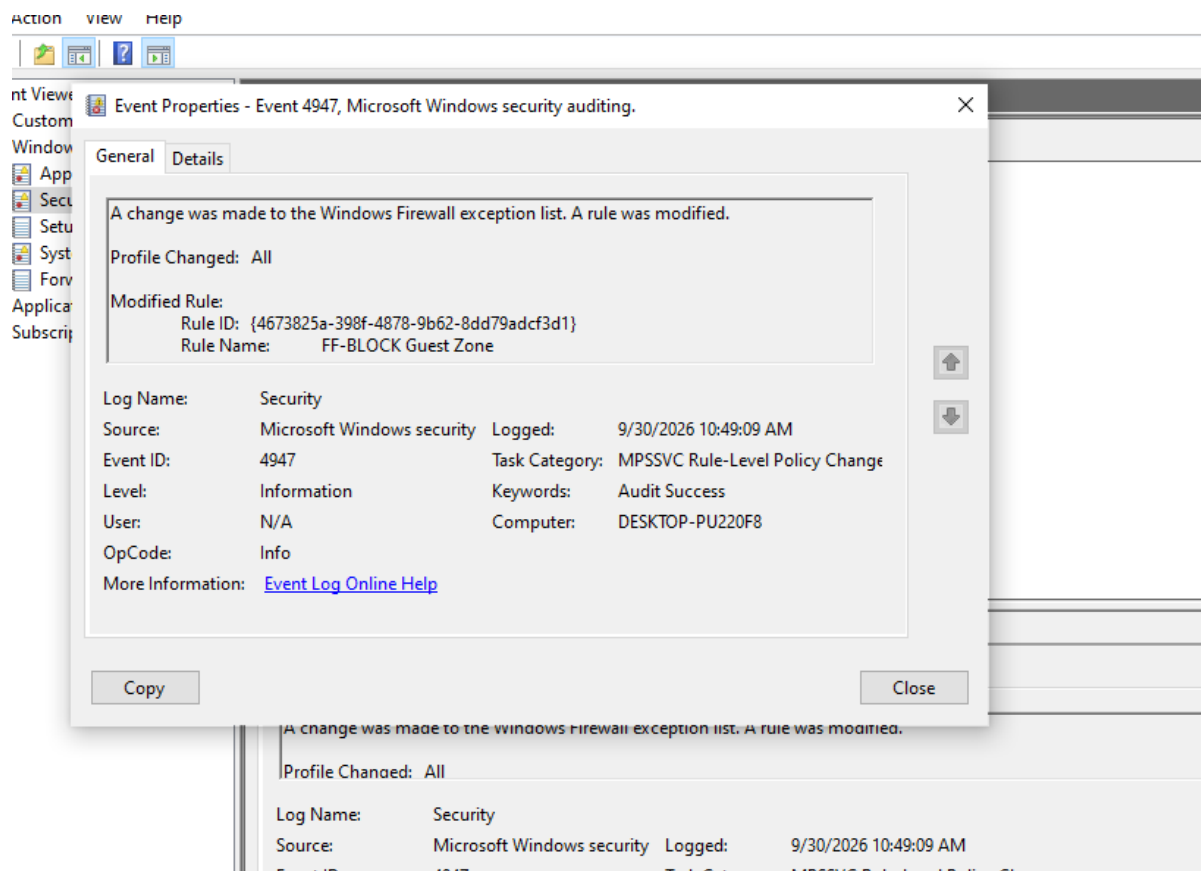


Tampering: Guest got in

Both changes were detected in Event Viewer:

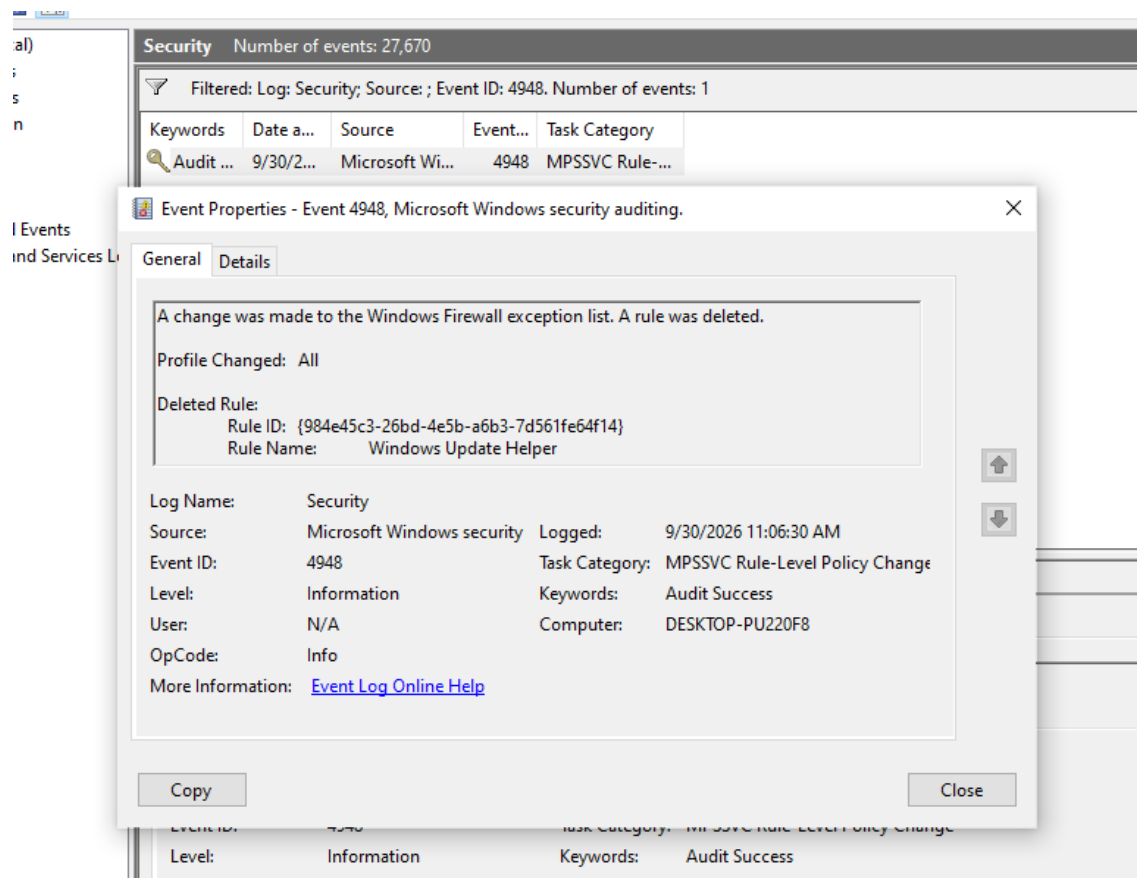


4946 rogue rule

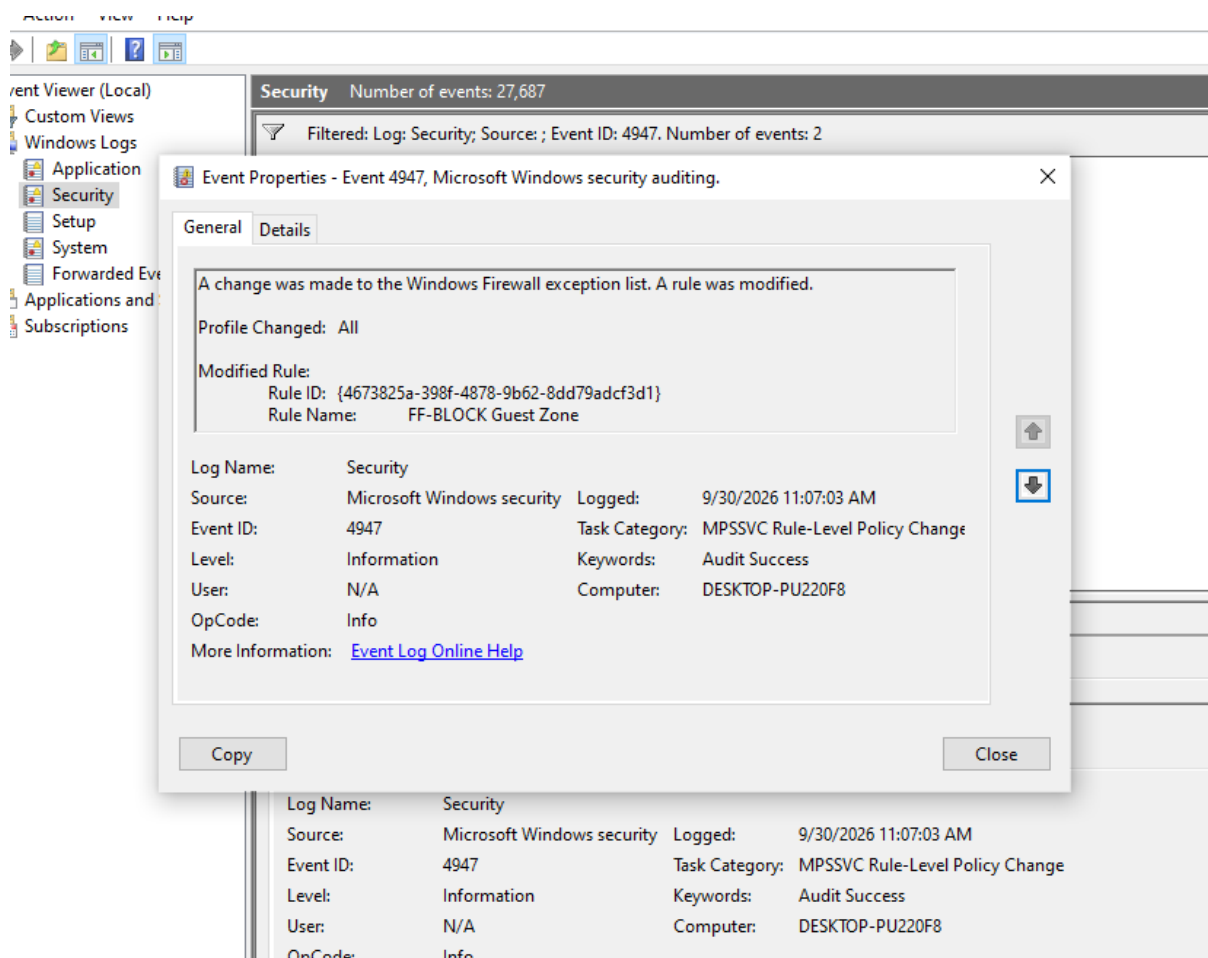


4947 block disabled

The fix was also logged:



4948 rogue deleted



4947 block restored

Time	Event ID	Action
10:49:09	4947	FF-BLOCK Guest Zone disabled
10:49:44	4946	Rogue rule "Windows Update Helper" added
After	-	Guest (.101) loaded the Billing Portal
11:06:30	4948	Rogue rule deleted
11:07:03	4947	FF-BLOCK Guest Zone re-enabled

The Rule IDs in the events matched the original rules exactly (`{4673825a-...}` for the Guest block, `{984e45c3-...}` for the rogue rule), confirming which rules were touched. On retest, the Guest zone was blocked again:

```

kali@kali: ~
Session Actions Edit View Help

(kali@kali)-[~]
$ curl --max-time 5 --interface 192.168.56.15 http://192.168.56.1:8080
<h1>ABC Freight Forwarders - Billing Portal</h1><p>Sirf Finance zone ke liye</p>

(kali@kali)-[~]
$ curl --max-time 5 --interface 192.168.56.35 http://192.168.56.1:8080
curl: (28) Connection timed out after 5007 milliseconds

(kali@kali)-[~]
$ curl --max-time 5 --interface 192.168.56.55 http://192.168.56.1:8080
curl: (28) Connection timed out after 5003 milliseconds

(kali@kali)-[~]
$ curl --max-time 5 --interface 192.168.56.101 http://192.168.56.1:8080
<h1>ABC Freight Forwarders - Billing Portal</h1><p>Sirf Finance zone ke liye</p>

(kali@kali)-[~]
$ curl --max-time 5 --interface 192.168.56.101 http://192.168.56.1:8080
curl: (28) Connection timed out after 5012 milliseconds

(kali@kali)-[~]
$ curl --max-time 5 --interface 192.168.56.101 http://192.168.56.1:8080
curl: (28) Connection timed out after 5052 milliseconds

(kali@kali)-[~]
$

```

Retest

F6 - Events do not show who made the change. Rule-change events showed `User: N/A`, so the log proves *what* changed and *when*, but not *who*. (See improvements.)

9. Key Decisions & Trade-offs

- **Default deny instead of blocking bad zones one by one.** Only zones with a business need get an allow rule. Any zone I forget (like Office) is blocked automatically, which is safer than trying to list every bad source.
- **Explicit block rules for Guest and Warehouse, even though default deny already blocks them.** In Windows Firewall, block rules win over allow rules, so if someone later adds a broad allow rule by mistake, Guest still stays blocked. The tampering test proved this: the attacker had to *disable* the block rule first, which created an extra log event.
- **IT gets access, Office does not.** IT maintains the system; Office staff have no billing duties. Giving Office access would widen the attack surface for no business benefit.

- **IP-range zones on one network instead of real VLANs.** This kept the lab free and runnable on one laptop. The trade-off is that the zones are not isolated at layer 2, which I document as a limitation.
- **Host laptop as the server instead of a separate Windows VM.** Saved RAM and setup time; all rules are scoped to the lab range and removed after testing.

10. What I Would Improve With More Time

- **Find out *who* made a change:** enable PowerShell Script Block Logging (Event 4104) so the exact tampering commands and user are recorded.
- **Alert automatically:** forward logs to a SIEM such as Wazuh and raise an alert whenever Event 4946, 4947 or 4948 appears.
- **Real segmentation:** build actual VLANs with pfSense between zones so isolation is enforced at the network level, not only on the server.
- **Egress rules:** restrict warehouse devices to only the internet destinations they need.

11. Repository Structure

```
Week3-Freight-Firewall/
|-- README.md
|-- SUMMARY.md
|-- CHANGELOG.md
|-- scripts/
|   |-- firewall-policy.ps1
|   |-- billing-portal.ps1
|   |-- kali-zone-tests.sh
|   |-- eventviewer-filters.xml
|-- screenshots/    (28 images, numbered by stage)
```

12. Cleanup

After recording the video, run the cleanup section at the bottom of `scripts/firewall-policy.ps1` to remove all **FF-** rules and turn auditing back off.

Summary - Approach and Reasoning

For Week 3 I built a network segmentation plan and firewall policy for ABC Freight Forwarders, a fictional independent freight forwarder. The main risk I focused on was that every device in a small logistics office usually sits on one flat network, so a driver's phone on guest Wi-Fi could reach the same billing system the finance team uses. Freight companies are frequent targets of invoice fraud and ransomware, so protecting the billing system was the priority.

My approach was to decide who actually needs the billing system and give access only to them. I divided the network into five zones by IP range: IT, Office, Finance, Warehouse and Guest. Only Finance (for invoicing) and IT (for maintenance) got an allow rule on port 8080. Guest and Warehouse got explicit block rules, and Office was left to Windows' default deny. I used the laptop as the company server and one Kali Linux VM that held a separate IP for each zone, so I could test all five zones from one machine.

Windows Event Viewer was the tool I used to prove the policy works. Logging for firewall connections is off by default, so I enabled it with auditpol first. After the rules were in place, all five zone tests passed. Event 5156 showed Finance being allowed to port 8080, Event 5152 showed Guest being dropped, and the portal's own log confirmed that only Finance and IT ever reached the service. One challenge was log noise: the Security log had more than 27,000 events, mostly my laptop's own internet traffic, so I wrote XPath filters by Event ID, IP address and port to find the exact evidence.

The most important test was tampering. Acting as an insider with admin rights, I disabled the Guest block rule and added an allow rule named "Windows Update Helper" so it would look harmless. Guest could then open the billing portal, which showed that segmentation can be broken with just two commands. However, Event Viewer recorded both changes (Events 4947 and 4946) 35 seconds apart, and the Rule IDs matched the original rules. I reversed the changes, the fix was also logged (4948 and 4947), and Guest was blocked again on retest.

The key lesson is that a firewall policy is only as strong as the monitoring around it. The logs showed what changed and when, but not who did it, so my next improvement would be PowerShell Script Block Logging and automatic alerts on firewall rule changes through a SIEM.

Changelog - Week 3 Network Segmentation & Firewall Policy Review

All times are from 30 Sep 2026 (host laptop clock).

Setup

- Chose the host laptop as the "server" instead of a separate Windows VM (no download needed, less RAM).
- Reset forgotten Kali password through GRUB (`init=/bin/bash`, `passwd kali`).
- Added a second VirtualBox adapter (Host-only) to Kali. Kali eth1 = 192.168.56.101, host = 192.168.56.1.

Baseline

- Ping from Kali: 174 sent, 0 received - ICMP blocked by default.
- Enabled three audit subcategories with `auditpol` (logging was off).
- First nmap attempt failed: typed `-pn` instead of `-Pn` (case matters). Corrected.
- `nmap -Pn 192.168.56.1`: all 1000 TCP ports filtered.

Service

- Python not installed, so built the Billing Portal with PowerShell HttpListener on TCP 8080.
- **Bug:** portal log printed an empty client IP. **Cause:** IP read after `Response.Close()`. **Fix:** read `RemoteEndPoint` first (v2).

Policy (09:01 - 09:04)

- Created FF-ALLOW Finance, FF-ALLOW IT, FF-BLOCK Guest, FF-BLOCK Warehouse. Office left to default deny.

Testing (~09:34)

- Added zone IPs to Kali (.45, .15, .35, .55). First attempt typed `apt` instead of `ip`; corrected.
- 5 / 5 zone tests passed. Portal log showed only .45 and .15.
- Event Viewer filter by event ID alone returned host noise (Chrome traffic). Rewrote as XPath filters by IP and port.
- First 5152 match was from the earlier nmap scan (07:55); refined filter and picked the post-rule event (09:34:15).

Tampering simulation

- 10:49:09 - disabled FF-BLOCK Guest Zone (4947)
- 10:49:44 - added rogue "Windows Update Helper" allow rule on 8080 (4946)
- Guest (.101) loaded the portal - segmentation bypassed.
- 11:06:30 - rogue rule removed (4948)
- 11:07:03 - FF-BLOCK Guest Zone re-enabled (4947)
- Retest: Guest timed out again.